Informe de pruebas OWASP ZAP

Evaluación de vulnerabilidades web — Proyecto PiedraAzul

Ingeniería de Software III · Seguridad de aplicaciones

Fecha	11 de octubre de 2026
Herramienta	OWASP ZAP (*ghcr.io/zaproxy/zaproxy:stable*)
Tipo de escaneo	Baseline (spider + reglas pasivas)
Objetivos	Frontend *http://localhost:4200* · API *http://localhost:8080*
Alcance	**No modificado** el código de la aplicación; artefactos en *seguridad-owasp/*
Referencia	OWASP Top 10 (2021)

1. Contexto revisado

Se revisó la configuración de seguridad ya existente en la aplicación, sin alterar el código fuente:

- Autenticación JWT con **Keycloak** (*APP_SECURITY_PROVIDER=keycloak*).
- Matriz de roles en *SecurityConfig* (ADMINISTRADOR, AGENDADOR, MEDICO, PACIENTE).
- Endpoints públicos acotados: login, registro de paciente y health.
- Frontend servido por **Nginx** (*nginx.conf*) sin cabeceras de seguridad adicionales.

Evidencia positiva: peticiones sin token a */api/citas* y */api/personas/pacientes* responden **401 Unauthorized**.

2. Resumen de hallazgos ZAP (frontend)

Nivel de riesgo	**Cantidad**
High	0
Medium	2
Low	6
Informational	2

Informes automáticos generados por la herramienta:

- *zap-reports/zap-frontend-baseline.html* (detalle completo)
- *zap-reports/zap-frontend-baseline.md* / *.json*
- *zap-reports/zap-backend-baseline.html* (API protegida; spider limitado por 401)

3. Vulnerabilidades reportadas (≥ 2 — OWASP Top 10)

V1. Content Security Policy (CSP) Header Not Set

Alerta ZAP	*10038* — Content Security Policy (CSP) Header Not Set
Riesgo ZAP	Medium
OWASP Top 10	**A05:2021 – Security Misconfiguration** (también mitiga riesgos de **A03:2021 – Injection / XSS**)
Evidencia	Respuestas HTML del frontend (*/*, */robots.txt*, etc.) sin cabecera *Content-Security-Policy*.
Impacto	El navegador no restringe orígenes de scripts, estilos ni recursos; aumenta la superficie ante XSS o inyección de contenido.
Recomendación	Configurar CSP en Nginx (p. ej. *default-src 'self'*; ajustar *script-src* / *style-src* según Angular).

V2. Missing Anti-clickjacking Header

Alerta ZAP	*10020* — Missing Anti-clickjacking Header
Riesgo ZAP	Medium
OWASP Top 10	**A05:2021 – Security Misconfiguration**
Evidencia	Respuestas del frontend sin *X-Frame-Options* ni *frame-ancestors* en CSP.
Impacto	La interfaz puede embeberse en un iframe de un sitio atacante (clickjacking) y engañar al usuario para realizar acciones no deseadas.
Recomendación	Añadir *X-Frame-Options: DENY* (o *SAMEORIGIN*) y/o *Content-Security-Policy: frame-ancestors 'none'*.

Hallazgos adicionales (Low / informativos)

Alerta ZAP	Riesgo	OWASP Top 10
Server Leaks Version (*Server: nginx/1.27.5*)	Low	A05 Security Misconfiguration
X-Content-Type-Options Header Missing	Low	A05 Security Misconfiguration
Permissions-Policy / COOP / COEP / CORP ausentes	Low	A05 Security Misconfiguration

4. Reproducción del escaneo

Con el stack en marcha (*docker compose up --build -d*):

```
# Frontend
docker run --rm -v "%CD%/seguridad-owasp/zap-reports:/zap/wrk/:rw" ^
  -t ghcr.io/zaproxy/zaproxy:stable ^
  zap-baseline.py -t http://host.docker.internal:4200 -m 5 ^
  -r zap-frontend-baseline.html -J zap-frontend-baseline.json -w zap-frontend-baseline.md

# Backend
docker run --rm -v "%CD%/seguridad-owasp/zap-reports:/zap/wrk/:rw" ^
  -t ghcr.io/zaproxy/zaproxy:stable ^
  zap-baseline.py -t http://host.docker.internal:8080 -m 5 ^
  -r zap-backend-baseline.html -J zap-backend-baseline.json -w zap-backend-baseline.md
```

Nota: el baseline de ZAP puede terminar con código de salida distinto de 0 cuando hay *WARN-NEW*; ello indica hallazgos, no un fallo de la herramienta.

5. Conclusión

OWASP ZAP confirmó **al menos dos vulnerabilidades** alineadas con el **OWASP Top 10 (2021)**, ambas de tipo **A05 Security Misconfiguration** en el frontend (CSP ausente y falta de protección anti-clickjacking). La API con JWT/Keycloak rechaza accesos no autenticados a recursos protegidos. No se alteró el código de backend, frontend, diagramas ni Compose; este informe y los reportes ZAP se encuentran únicamente en *seguridad-owasp/*.
